

Ola 3F Tokens

Alertas de vencimiento y rotacion de tokens

Fecha base: 2026-05-08

Fuente: 20-ola-3f-alertas-rotacion-tokens.md

Documento generado para ejecutar el piloto de P&Pmis Ai SaaS como plataforma colaborativa en línea de Project Controls, con trazabilidad por roles, workflows, Cost Manager, AWP, contratos, claims y readiness.

Contenido

- Objetivo
- Alcance Cerrado En Esta Iteracion
- Endpoint
- Criterios De Alerta
- Uso Operativo
- Controles
- Gate Operativo
- Checklist De Cierre
- Siguiente Ola Recomendada
- Decision

Fecha base: 2026-05-08

Objetivo

Evitar que las integraciones del piloto dependan de tokens proximos a vencer sin visibilidad operativa. Esta ola agrega un tablero API de alertas para que el equipo de control pueda rotar credenciales antes de que afecten descargas CSV, JSON, ZIP o XLSX.

Alcance Cerrado En Esta Iteracion

- Endpoint GET /api/v1/projects/{project_id}/integration-token-alerts.
- Parametro warning_days con rango permitido de 1 a 90 dias.
- Conteo de tokens activos.
- Conteo de tokens activos vencidos.
- Conteo de tokens activos proximos a vencer.
- Conteo de tokens revocados.
- Alertas warning para tokens activos que vencen dentro de la ventana configurada.
- Alertas critical para tokens activos ya vencidos.
- Reglas de seguridad alineadas con gestion de tokens: membresia del proyecto y permiso can_configure.
- Gate tools/pilot_integration_gate.ps1 actualizado para validar alertas y rechazo 403 en proyecto restringido.

Endpoint

```
GET /api/v1/projects/{project_id}/integration-token-alerts?warning_days=14
Authorization: Bearer <jwt_usuario>
```

Solo roles con can_configure pueden consultar alertas de tokens.

Respuesta:

- project_id
- warning_days
- generated_at
- active_count
- expiring_count
- expired_count
- revoked_count
- alerts

Cada alerta incluye:

- id
- project_id
- name
- token_prefix
- status
- datasets
- formats
- expires_at
- days_to_expiry
- severity
- message
- last_used_at

Criterios De Alerta

Condicion	Severidad	Accion
Token activo vencido	critical	Revocar o rotar inmediatamente
Token activo con vencimiento dentro de warning_days	warning	Crear token nuevo y actualizar consumidor
Token revocado	Sin alerta	Se informa solo en revoked_count
Token activo fuera de ventana	Sin alerta	Mantener vigilancia normal

Uso Operativo

Consultar alertas de los proximos 14 dias:

```
$headers = @{ Authorization = "Bearer <jwt_usuario>" }  
Invoke-RestMethod `   
-Uri "http://localhost:8000/api/v1/projects/1/integration-token-alerts?warning_days=14" `   
-Headers $headers
```

Rotar un token proximo a vencer:

```
$payload = @{  
    name = "BI export token rotado"  
    datasets = @("cost_sheet", "documents")  
    formats = @("json", "csv", "both", "xlsx")  
    expires_in_days = 30  
} | ConvertTo-Json  
  
$newToken = Invoke-RestMethod `   
-Method Post `   
-Uri "http://localhost:8000/api/v1/projects/1/integration-tokens" `   
-Headers $headers `   
-ContentType "application/json" `   
-Body $payload
```

Actualizar el consumidor externo con \$newToken.token, validar una descarga y luego revocar el token anterior:

```
Invoke-RestMethod `   
-Method Post `   
-Uri "http://localhost:8000/api/v1/projects/1/integration-tokens/<token_id_anterior>/revoke"   
`   
-Headers $headers
```

Controles

- El token completo solo se entrega al crear la credencial.
- El endpoint de alertas muestra solamente token_prefix.
- Las alertas no habilitan descarga ni escritura externa.
- Los tokens vencidos siguen rechazando consumo con HTTP 401.
- Los tokens fuera de alcance de dataset siguen rechazando consumo con HTTP 403.
- El gate valida que un token de 7 dias aparezca como warning en una ventana de 14 dias.
- Un usuario sin membresia en el proyecto no puede consultar alertas.

Gate Operativo

Ejecutar:

```
powershell -ExecutionPolicy Bypass -File .\tools\pilot_integration_gate.ps1
```

El gate actualizado valida:

- Creacion de token gobernado.
- Alcance del token sobre cost_sheet y documents.
- Generacion de ZIP y XLSX con token.
- Alerta warning para el token de 7 dias.
- Revocacion y rechazo posterior HTTP 401.
- Rechazo HTTP 403 para usuario sin membresia al consultar alertas.
- Catalogo auditable de descargas.

Checklist De Cierre

```
docker compose build api
docker compose up -d api
docker compose exec -T api pytest
docker compose exec -T frontend npm run build
powershell -ExecutionPolicy Bypass -File .\tools\pilot_integration_gate.ps1
powershell -ExecutionPolicy Bypass -File .\tools\pilot_check.ps1
```

Siguiente Ola Recomendada

La siguiente ola puede avanzar a:

- Retencion configurable del catalogo de descargas.
- Reporte ejecutivo de integraciones por consumidor.
- Staging de importacion XER/XML con comparacion antes/despues.
- Validacion de paquetes ZIP de entrada con manifiesto esperado.

Decision

Con Ola 3F el piloto gana una señal temprana de rotación de credenciales. Esto permite operar integraciones con terceros sin depender de memoria manual ni exponer tokens completos en reportes operativos.